HUTECH
Đại học Công nghệ Tp.HCM

BỘ GIÁO DỤC VÀ ĐÀO TẠO

TRƯỜNG ĐẠI HỌC CÔNG NGHỆ TP. HCM

Trần Tăng Trường Thịnh 2387701939

BÀI 5: KHAI THÁC LỖ HỔNG CSRF

5.1 THỰC HIỆN TẤN CÔNG CSRF SỬ DỤNG CÔNG CỤ COOKIE CADGER

- Lý do sử dụng Wireshark và cURL: Do link tải công cụ *Cookie Cadger* bị lỗi 404, nhóm sử dụng **Wireshark** (để bắt gói tin mạng) kết hợp **cURL** (để gửi lại request) – phương pháp này mang lại kết quả và bản chất kỹ thuật hoàn toàn tương đương với Cookie Cadger.
- Mô hình thực nghiệm: Máy nạn nhân Windows (192.168.44.135) kết nối tới Web Server trên Kali Linux (192.168.44.134:8080).

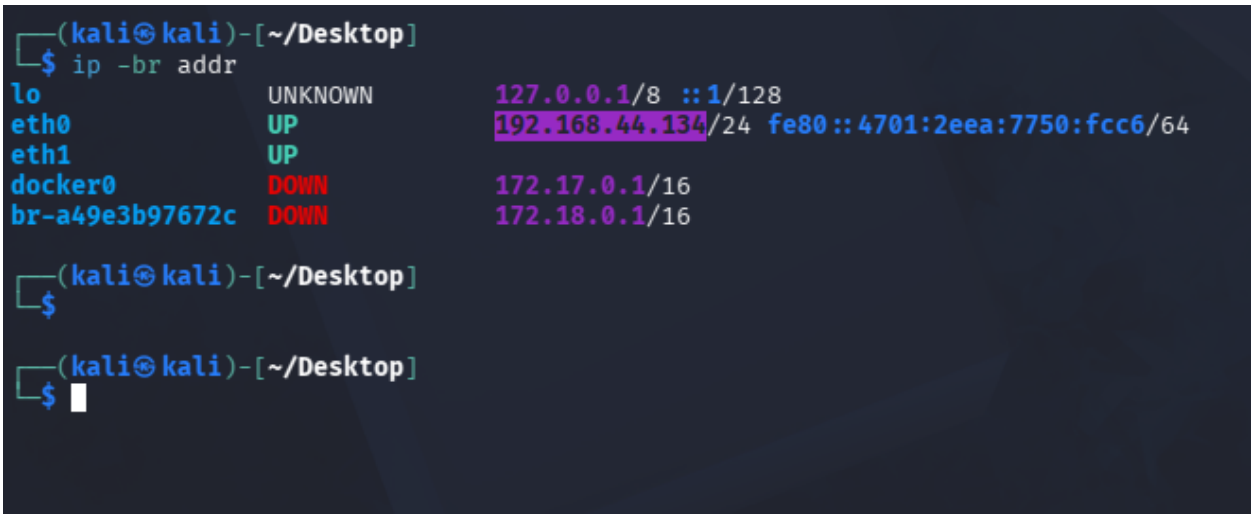
Quá trình thực hiện:

1. Khởi tạo phiên: Người dùng trên máy Windows đăng nhập thành công tài khoản *root / toor* vào trang *Message Board* và được cấp cookie AUTH. *(Hình 5, 6)*
2. Bắt gói tin: Trên Kali, sử dụng Wireshark với bộ lọc *tcp.port == 8080 && http.cookie*. Do ứng dụng chạy trên giao thức HTTP không mã hóa, Wireshark bắt được giá trị cookie dạng văn bản rõ: *AUTH=978a2f1b6d1b30801ef51df609f036ff. (Hình 8, 9)*
3. Chiếm quyền phiên (Replay Attack): Kẻ tấn công dùng curl trên Kali gửi request đính kèm cookie vừa đánh cắp:

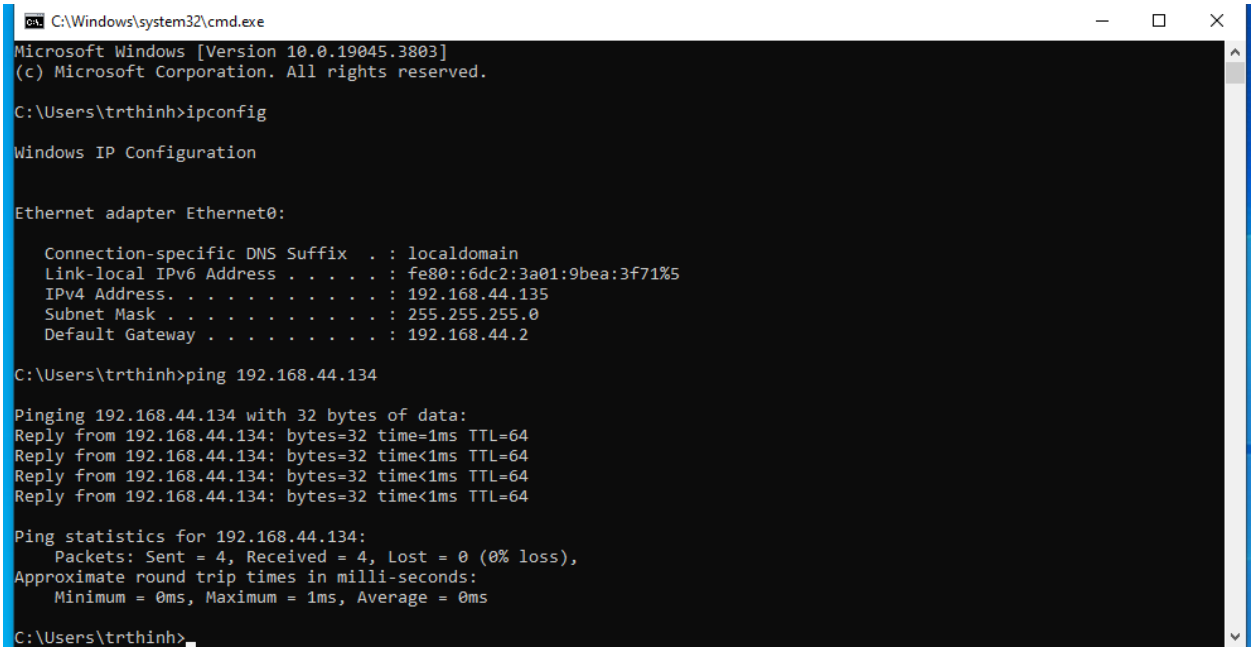
curl -i -H "Cookie: AUTH=978a2f1b6d1b30801ef51df609f036ff" http://192.168.44.134:8080/cookielogin/messageboard.php

Kết quả: Máy chủ trả về mã 200 OK kèm thông báo **Welcome Linux Root User!.** Kẻ tấn công truy cập thành công vào phiên của nạn nhân mà không cần mật khẩu. *(Hình 10)*

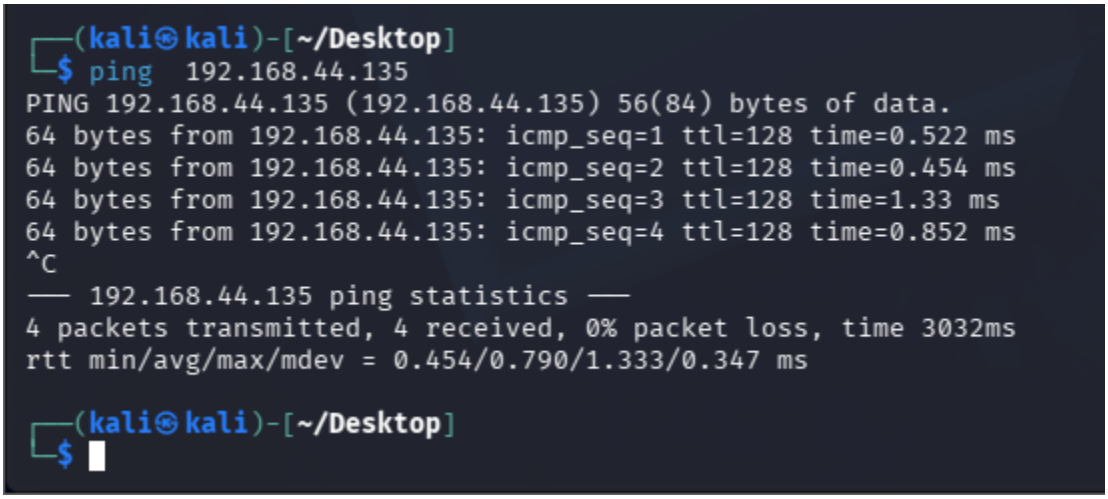
- **Kết luận & Phòng chống:** Lỗ hổng xuất phát từ việc truyền dữ liệu qua HTTP không mã hóa. Biện pháp khắc phục là bắt buộc sử dụng HTTPS và thiết lập thuộc tính bảo vệ cho cookie (*Secure, HttpOnly, SameSite*).



Hình 1: Kiểm tra địa chỉ IP của máy kali *192.168.44.134*



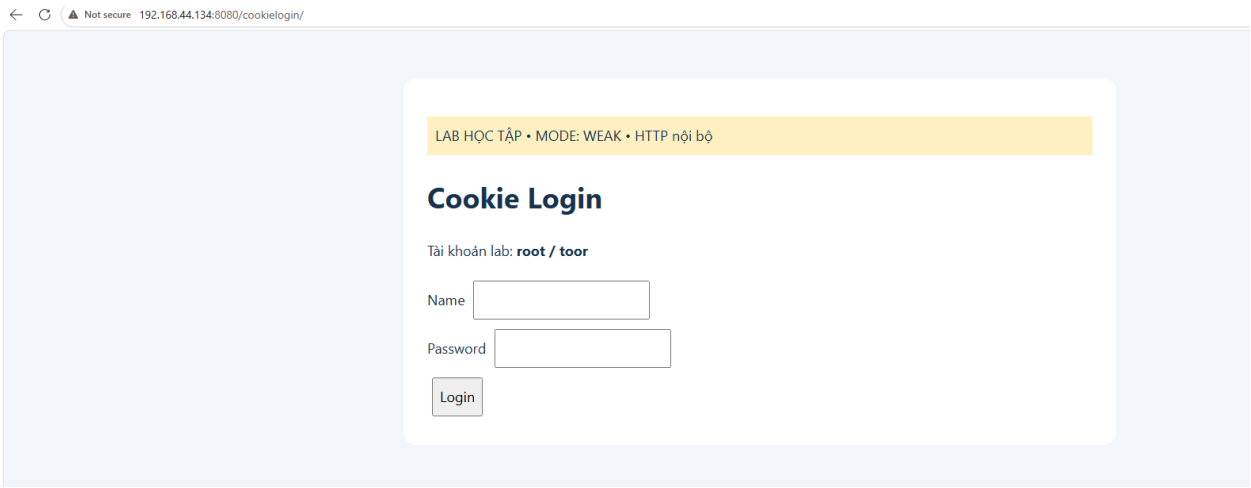
Hình 2: Kiểm tra kết nối giữa máy bằng *ping* từ máy windows sang kali với IP máy windows *192.168.44.135*



Hình 3: Ping máy Windows từ máy Kali



Hình 4: Khởi chạy máy chủ web mô phỏng ứng dụng Cookie Login trên Kali Linux

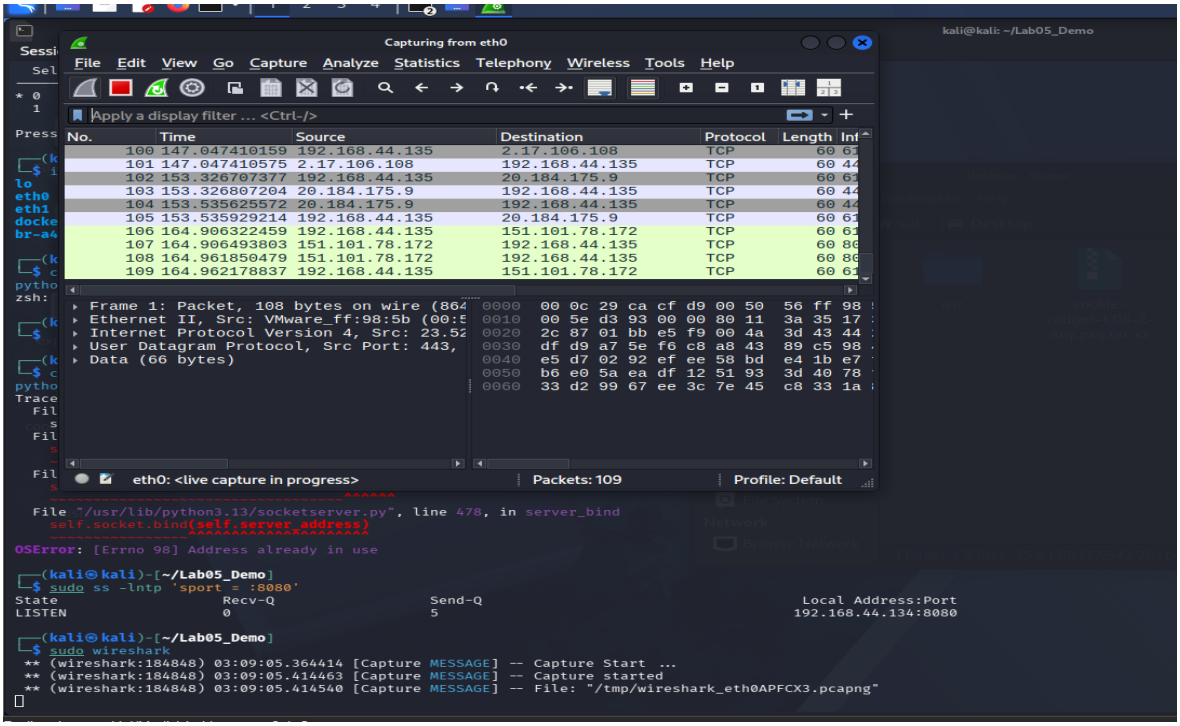


Hình 5: Giao diện đăng nhập Cookie Login được truy cập từ máy Windows

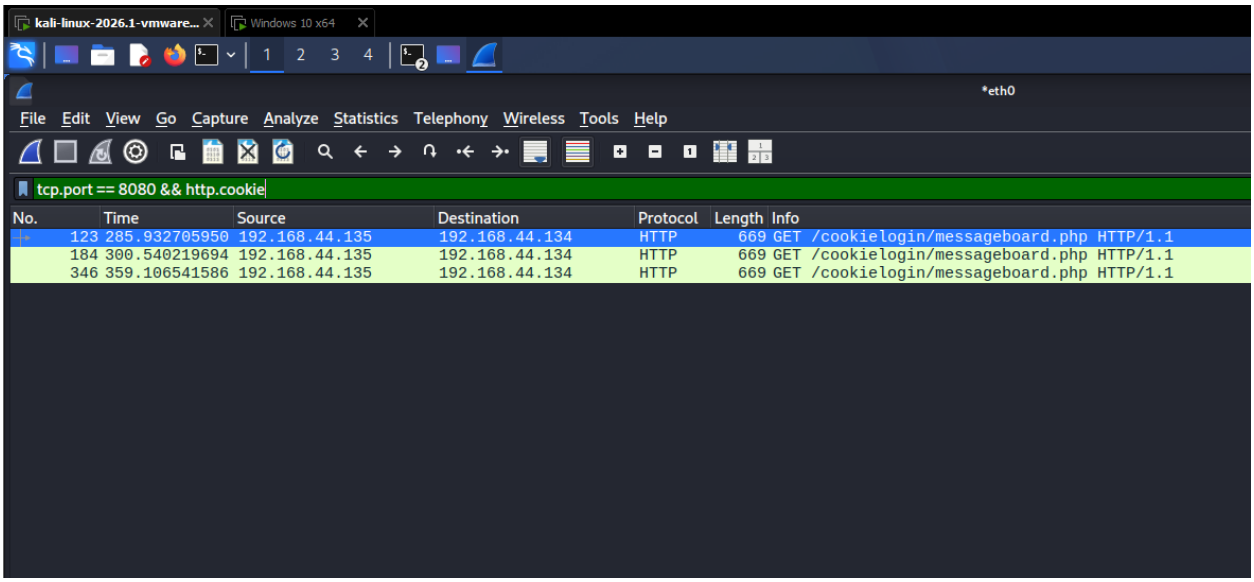


x

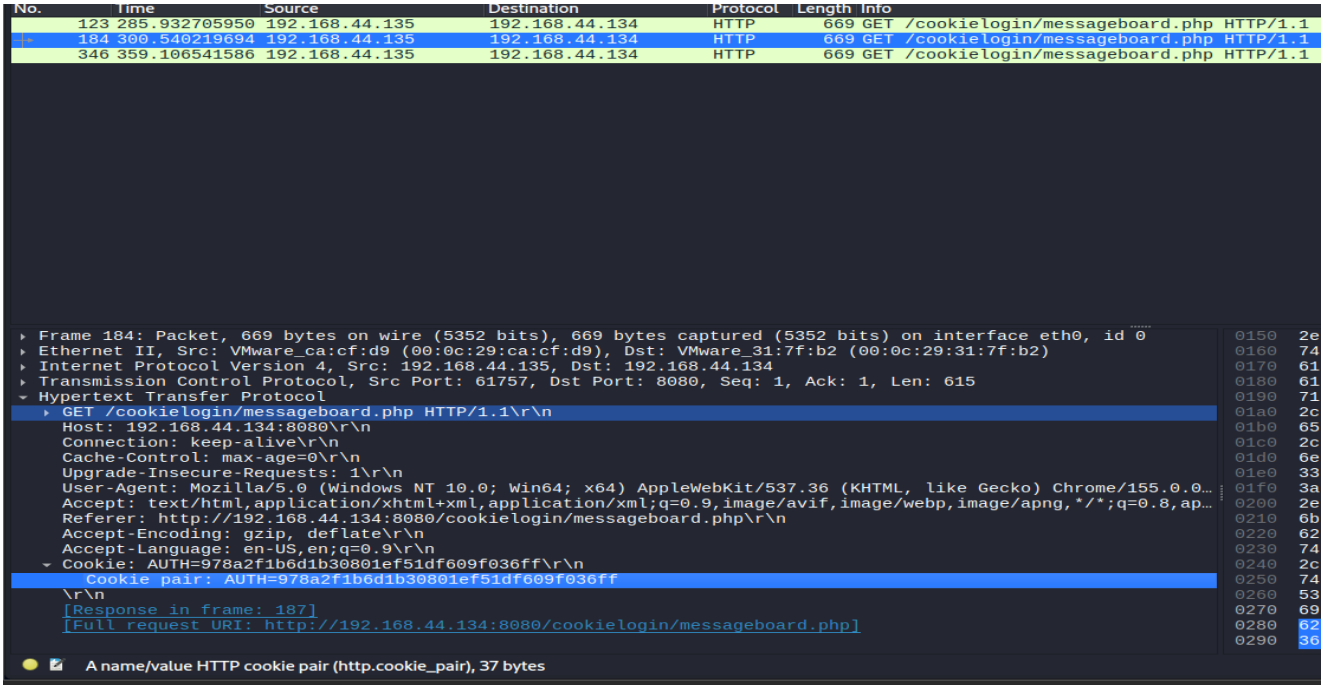
Hình 6: Đăng nhập thành công với tài khoản mặc định *root / toor*



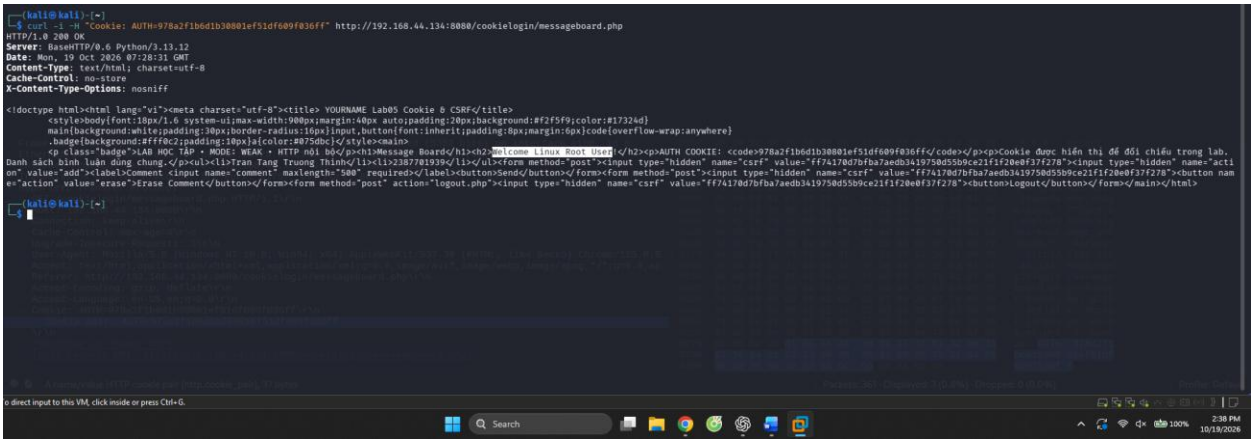
Hình 7: Khởi động Wireshark trên card mạng **eth0** để bắt lưu lượng trong môi trường lab.



Hình 8: Các gói tin HTTP chứa cookie phiên được lọc bằng Wireshark.



Hình 9: Chi tiết gói tin HTTP bị bắt cho thấy giá trị Cookie *AUTH* được truyền dạng văn bản rõ (cleartext).



Hình 10: Thực hiện phát lại yêu cầu (Replay Request) bằng *curl* cùng Cookie bị đánh cắp để chiếm phiên người dùng.

5.2 THỰC HIỆN TẤN CÔNG ATTACKDIRECT CSRF SỬ DỤNG CÔNG CỤ EDITTHISCOOKIE VÀ WIRESHARK

- Mục đích: Kiểm chứng cơ chế xác thực phiên bằng Cookie và thực hiện chiếm lại phiên đăng nhập mà không cần mật khẩu.
- Công cụ sử dụng: Trình duyệt Chrome, tiện ích Cookie-Editor (thay thế cho EditThisCookie đã lỗi thời), công cụ Wireshark trên Windows và mục tiêu attackdirect.samsclass.info.

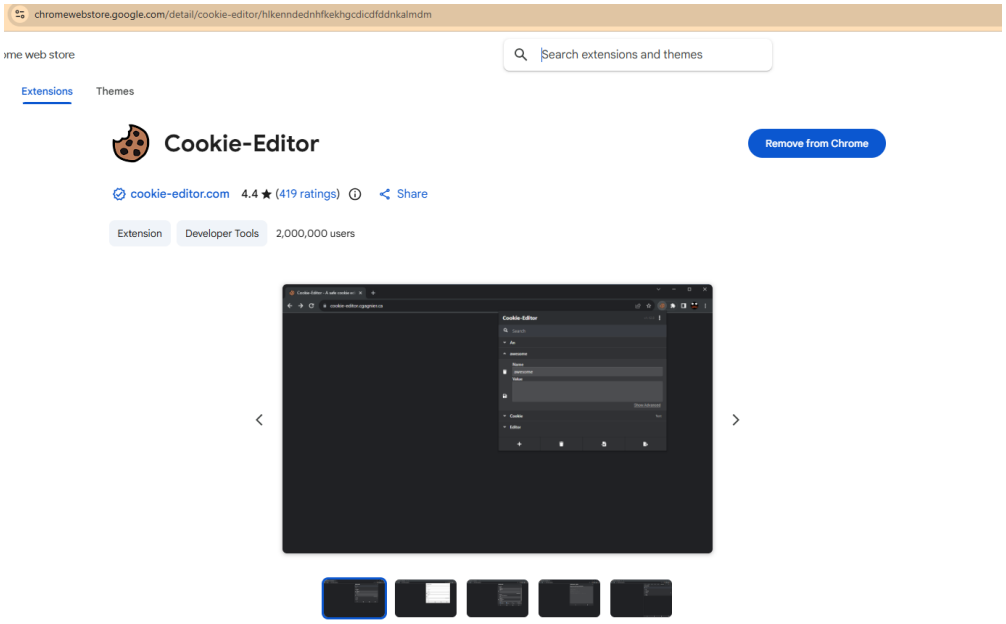
Quá trình thực hiện:

1. Quan sát Cookie: Đăng nhập tài khoản root / toor thành công. Mở Cookie-Editor và Wireshark xác nhận cookie phiên được cấp là: *AUTH=63a9f0ea7bb98050796b649e85481845*. *(Hình 13)*
2. Đăng xuất & kiểm tra từ chối: Người dùng nhấn ***Logout***, cookie *AUTH* chuyển thành *INVALID*. Khi truy cập lại trang messageboard.php, máy chủ từ chối và báo lỗi ***"INVALID FAIL".*** *(Hình 17)*
3. Cấy Cookie (Injection): Mở tiện ích Cookie-Editor, thay thế giá trị INVALID bằng chuỗi hash hợp lệ đã bắt từ Wireshark (*63a9f0ea7bb98050796b649e85481845*) rồi lưu lại. *(Hình 18)*
4. Chiếm phiên thành công: Tải lại trang. Máy chủ chấp nhận cookie và cấp quyền truy cập lại trang Message Board với lời chào ***"Welcome Linux Root User!"*** mà không cần nhập mật khẩu. *(Hình 19)*

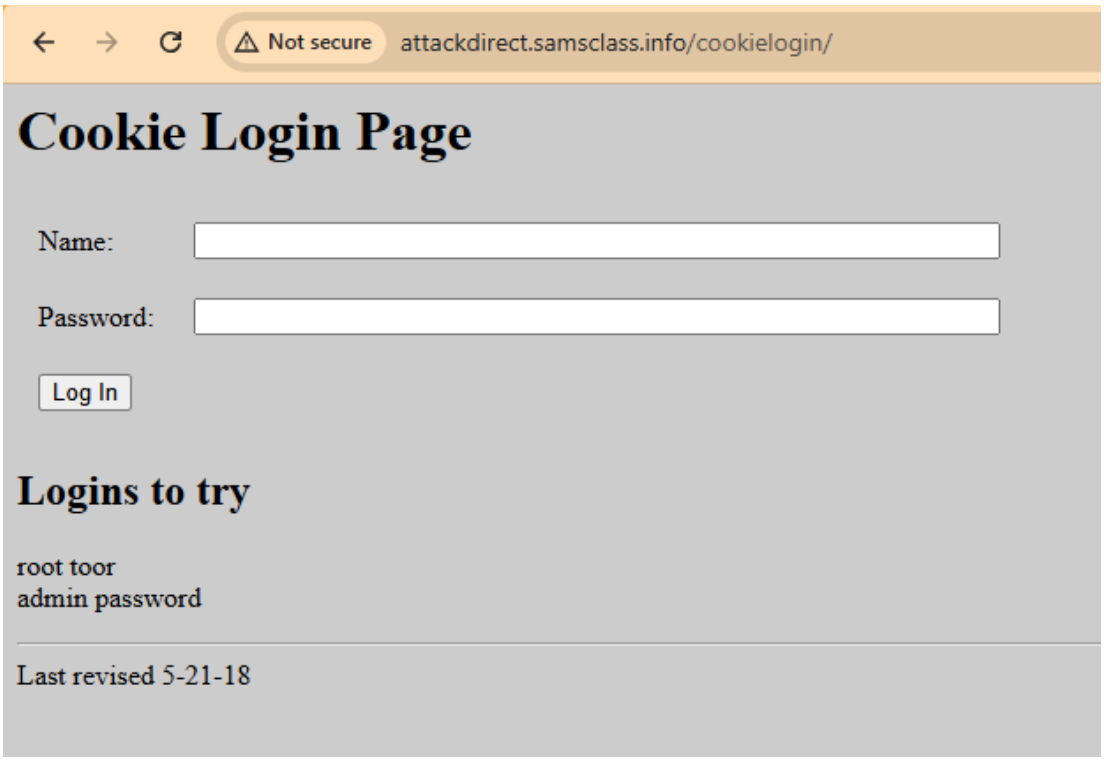
Đánh giá & Biện pháp phòng chống:

- Nguyên nhân: Ứng dụng chạy trên HTTP không mã hóa làm lộ cookie qua Wireshark; đồng thời thao tác Logout chỉ đổi giá trị cookie ở trình duyệt mà không hủy phiên thực sự trên máy chủ (thiếu Server-side Session Revocation).

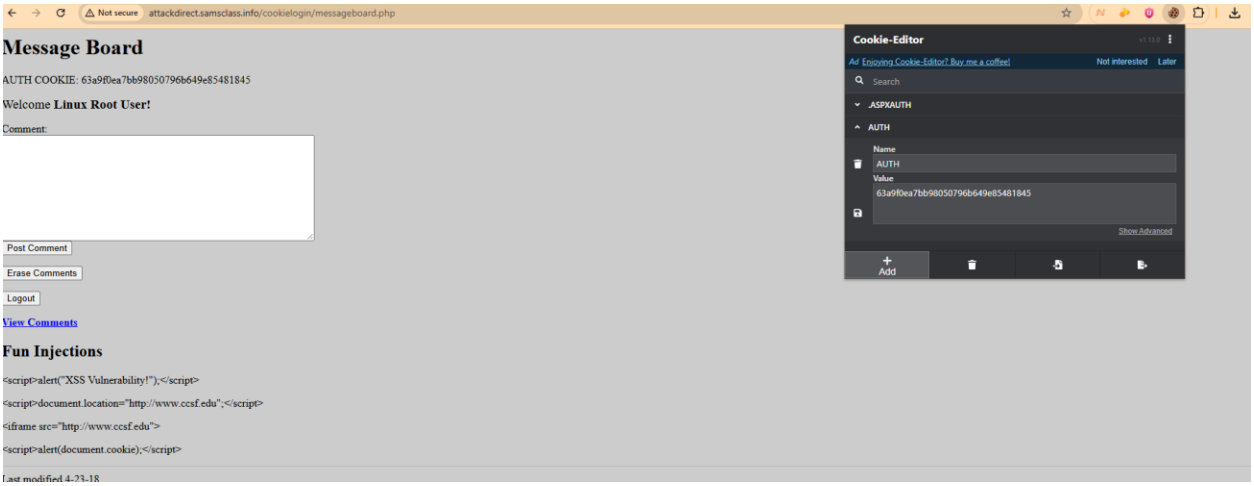
- Biện pháp khắc phục:
    1. Hủy bỏ hoàn toàn phiên làm việc phía máy chủ khi người dùng Logout.
    2. Bắt buộc dùng giao thức **HTTPS** và bật các cờ bảo vệ cho Cookie (HttpOnly, Secure, SameSite=Strict).
    3. Ràng buộc phiên làm việc với địa chỉ IP hoặc thông tin thiết bị (User-Agent).



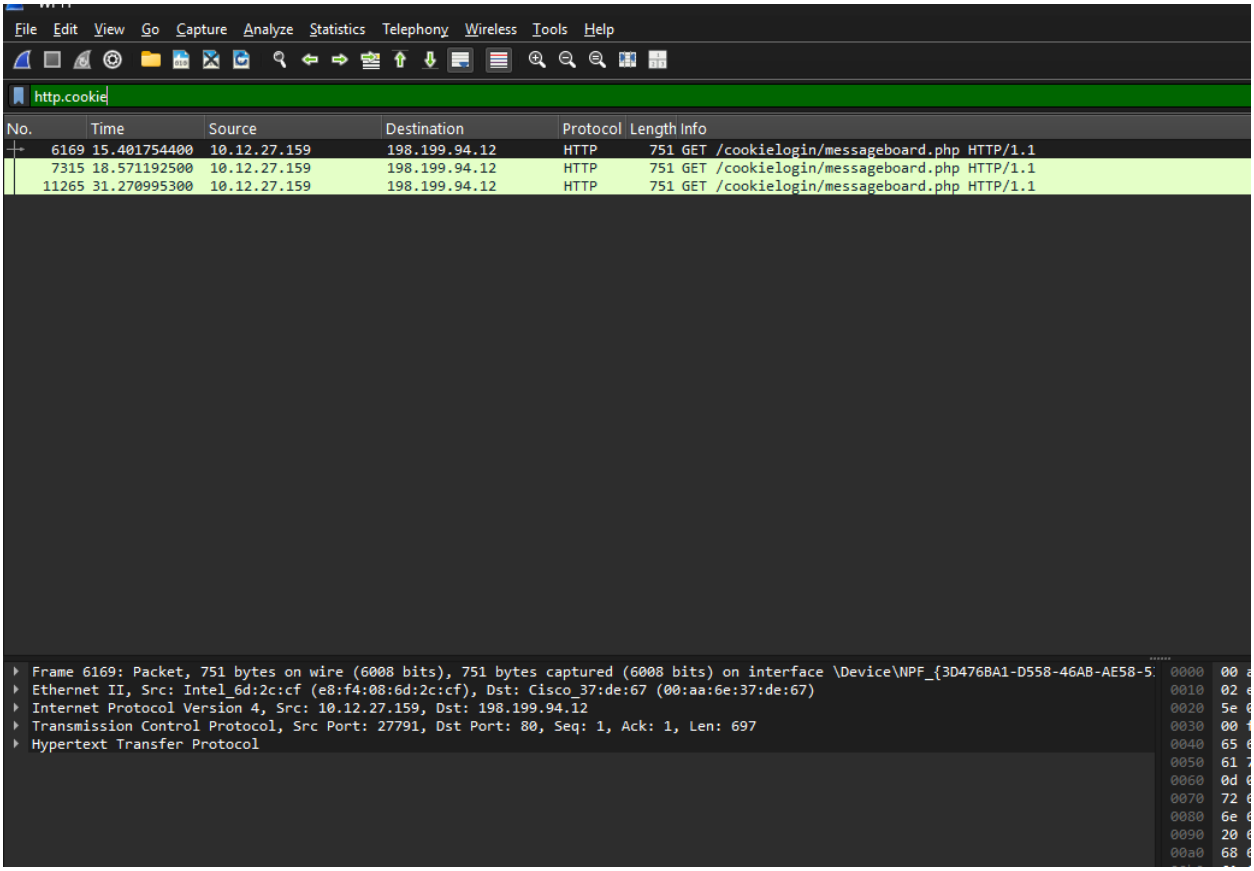
Hình 11: Cài đặt tiện ích mở rộng Cookie-Editor trên Google Chrome thay thế cho EditThisCookie.



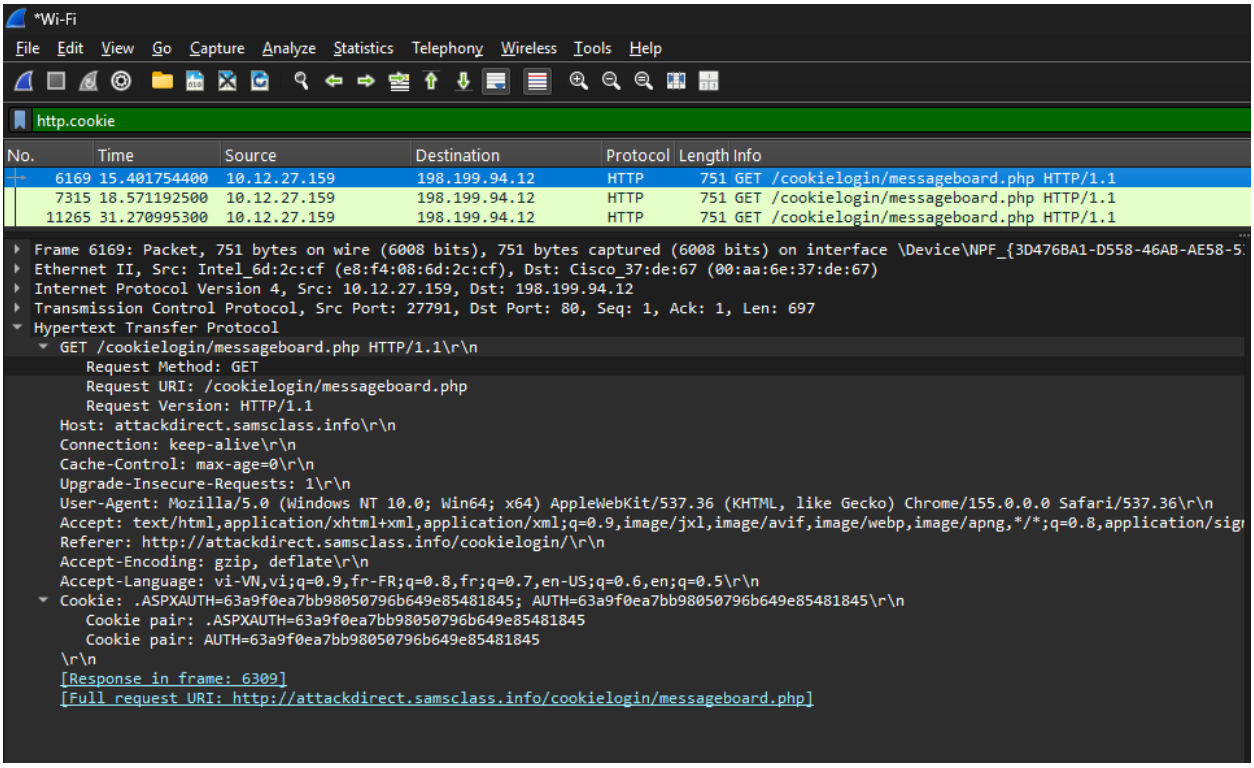
Hình 12: Đăng nhập kiểm tra trang web



Hình 13: Sử dụng tiện ích Cookie-Editor để kiểm tra và quan sát Cookie xác thực **AUTH** trên trang Message Board.



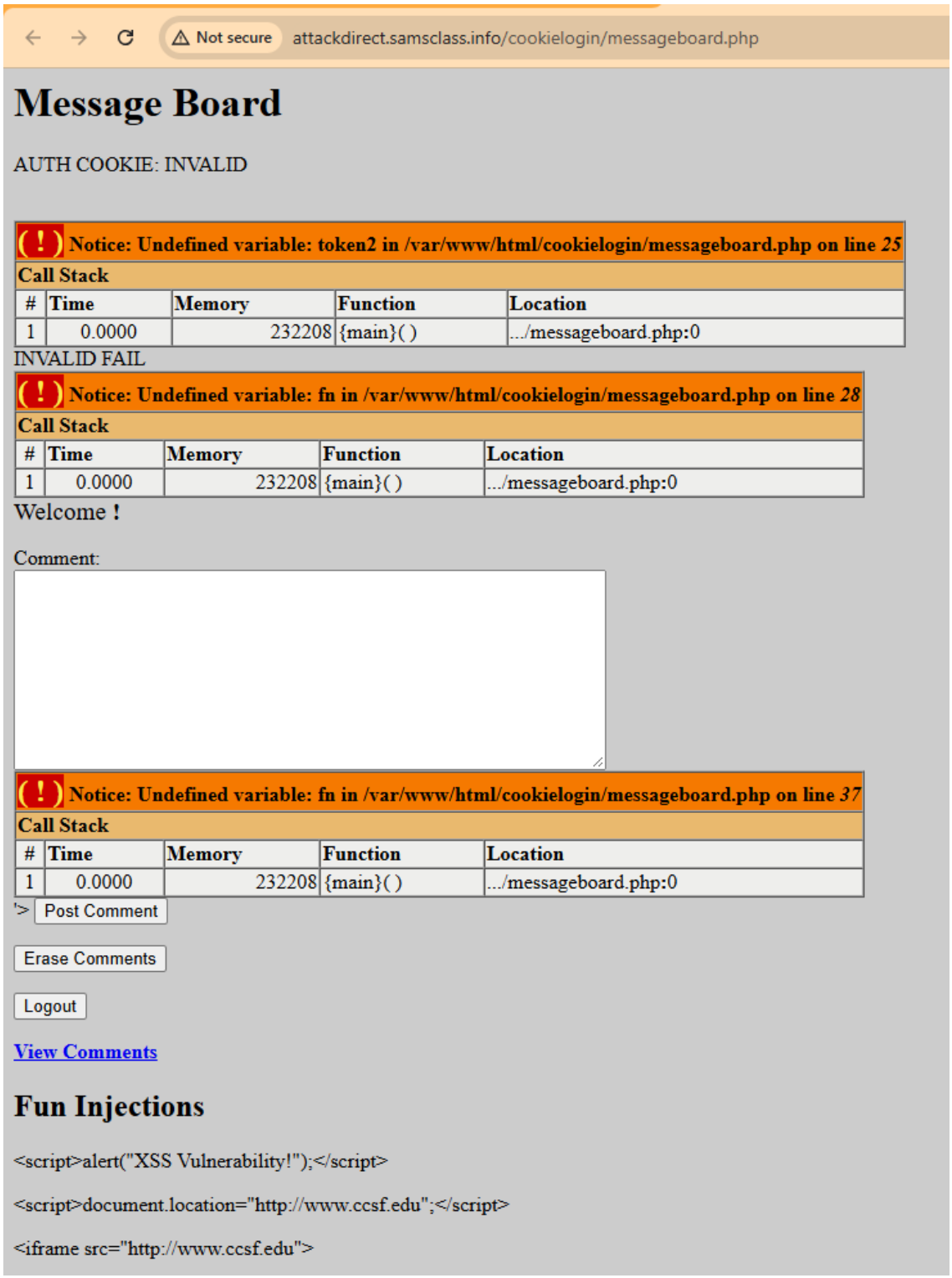
Hình 14: Sử dụng Wireshark với bộ lọc http.cookie để bắt các yêu cầu HTTP mang cookie phiên.



Hình 15: Chi tiết gói tin HTTP Request trên Wireshark để lộ chuỗi Cookie xác thực AUTH.



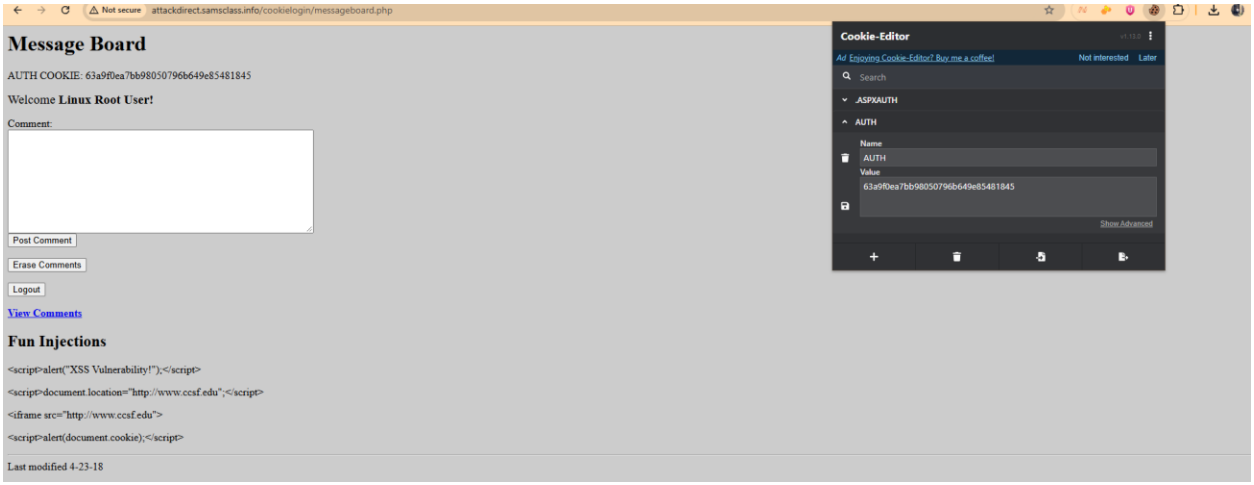
Hình 16: Đăng xuất khỏi bảng tin Message Board



Hình 17: Kiểm tra truy cập khi cookie mang giá trị INVALID



Hình 18: Dán lại giá trị Cookie AUTH hợp lệ đã đánh cắp vào tiện ích Cookie-Editor.



Hình 19: Chiếm phiên đăng nhập thành công (Direct CSRF / Session Hijacking) sau khi cấy lại Cookie AUTH.